ONE-PAGE BRIEF

Post-quantum cryptography review: rustcrypto-rsa @ f96c4b5d629a

Client: RustCrypto project — public repository (passive review) · Source: github.com/RustCrypto/RSA, commit `f96c4b5d629a` · Reviewed: 2026-11-06 13:50 UTC · Risk profile: Security software vendor

POST-QUANTUM MATURITY

Level 0 of 4

no post-quantum cryptography

FINDINGS

0 Critical **0** High **1** Medium **2** Low **1** Info

QUANTUM TIMELINE (MOSCA: X + Y − Z)

Key establishment: 10 + 3 − 8 = 5 → **too late**

Next step: Inventory where classical public-key cryptography protects long-lived data and keys, and choose the first migration: usually a hybrid TLS key exchange and wrapped keys.

WHAT MATTERS MOST

Medium QSI-2026-18754	**Quantum-vulnerable RSA: role not determined (5 file(s))** preliminary What to do: Classify each usage, record data lifetimes, and plan migration to ML-DSA (FIPS 204) or SLH-DSA (FIPS 205), in a hybrid/composite form…
Low QSI-2026-18756	**crypto-bigint 0.7.5 is affected by RUSTSEC-2026-0387 (no severity rating)** preliminary What to do: Triage the advisory; upgrade to a fixed version (0.7.6) if it applies.
Low QSI-2026-18757	**ctutils 0.4.2 is affected by RUSTSEC-2026-0385 (no severity rating)** preliminary What to do: Triage the advisory; upgrade to a fixed version (0.4.4) if it applies.

WHAT THE QUANTUM-VULNERABLE CRYPTOGRAPHY PROTECTS

Role	Algorithms	What to do
Medium role not determined	RSA	Classify each usage, record data lifetimes, and plan migration to ML-DSA (FIPS 204) or SLH-DSA (FIPS 205)…

KNOWN VULNERABLE COMPONENTS

Advisories for the versions in use: 2; each needs checking against the code.

Static review of source code and manifests; files analysed: 35. No requests were sent to the owner's systems.

Full report, content SHA-256: `ac412823ecaa175f8be5a76d35eb3ccfb46ff2a08a22c9a4b48c91ad8b0f3e93`

Full report signature (report.sig.json): Ed25519 key, SHA-256 fingerprint `5b3cf9c9bd0fa54447e2b5dfa7a6bab569bd0c666fa46949599e5c348d17083e`. bundle.sig.json lists the SHA-256 of every file in this bundle and is signed too; verify-bundle checks it offline.

Preliminary findings need confirmation in the code; the full report gives the evidence, the limits of each check and how to re-test.